

Scenario Recommendations and Confidence

Scenario Recommendations and Confidence I

The 8 scenarios below map the evaluation of sec. 4 onto recurring situations. Recommendations are conditional judgments from documented designs and advisories, not an absolute ordering across every threat model. The assumptions matter enough that changing the hardware, the required software, or the adversary can change the recommendation; the change conditions state what would.

Scenario recommendations

Scenario recommendations I

tbl. 1 compresses the recommendations. Each recommended direction names the architectural property doing the work, not merely the distribution label, because the properties — containment, authority, integrity, update operations, and the rest of the 9 (tbl. 2) — are what survive a change of vendor.

Scenario recommendations I

Table 1: The 8 scenario recommendations: the architectural property doing the work, the direction, and the condition that would change it

Scenario	Recommended direction	Condition that could change it
High-risk personal workstation with distinct sensitive identities	Qubes, with deliberately separated domains, disposable intake, minimal administration, and prompt updates; release 4.3.0's continued disaggregation of the GUI and administrative stacks makes the compartmentalized workflow easier to keep (sec. 5)	Incompatible hardware, essential unsupported software, or inability to sustain the compartmentalized workflow
Conventional Linux desktop with a hardening priority	Evaluate secureblue first against actual application requirements — version 4.9.1 ships a SUID-less baseline with SELinux-enforced namespace restrictions; Fedora Workstation or an atomic Fedora desktop when a more standard environment is more sustainable (sec. 7)	Hardening restrictions require broad exceptions, or project maintenance does not meet the owner's assurance requirements
Skilled operator prioritizing auditable configuration and replaceable environments	NixOS, paired with explicit runtime confinement, boot-integrity decisions, runtime secret handling, and a disciplined update process; the project's hardening wiki now documents a coherent baseline after the hardened profile's removal, and the provenance tooling of sec. 14 strengthens the audit story (sec. 6)	The custom security integration becomes too complex to review and maintain
Autonomous coding or research agents processing hostile material	Disposable task VMs or comparable isolated workers, with controlled egress and externally mediated credentials; Nix can help construct the workers (sec. 8)	Tasks demand high-impact access that cannot be safely scoped; those actions remain separately authorized

Scenario recommendations II

Controlled Kubernetes node fleet	Talos; also assess Bottlerocket where its container-host ecosystem fits; Talos 1.12's configurable TPM PCR policies make its Secure Boot posture declarable per fleet (sec. 8)	Orchestrator, hardware, extension, or operational requirements conflict with the reduced host interface
General enterprise server	RHEL or Ubuntu LTS with explicit support scope and tested policies; Debian or NixOS where the operator can own the maintenance obligations (sec. 8)	Package coverage, response requirements, or configuration expertise favor a different support model
Anonymity or reduced local traces	Whonix for persistent separated work; Tails for amnesic sessions (sec. 9)	The actual priority is protecting local credentials from an already-compromised application rather than anonymity
High-assurance architectural research	Track seL4 and Genode/Sculpt while evaluating the complete deployed system and its proof boundary (sec. 9)	Production compatibility, drivers, tooling, or operational assurance outweighs theoretical elegance

Scenario recommendations I

Two rows deserve emphasis. Autonomous agent hosting is the scenario the threat model of sec. 3 is built around: the recommendation is disposable isolation plus externally mediated credentials, not a host choice, and no reviewed distribution turns an ordinary container or VM into that boundary by naming. Anonymity is deliberately narrow: Whonix's gateway/workstation model and Tails' amnesic design address trace reduction and session separation (W. Project 2026a; T. Project 2026), and neither makes an authorized agent harmless — protecting local credentials from an already-compromised application is the workstation containment problem, not the anonymity problem (W. Project 2026b). Matching scenario to priority is the whole recommendation.

Scenario recommendations I

The refresh behind these rows is current, and it is worth stating what changed without overstating it. Qubes 4.3.0 reached general availability with the GUI stack and administrative services disaggregated out of dom0, continuing the small-privileged-interface trajectory (Project 2025). secureblue's v4.9.1 ships a SUID-less userland with SELinux-enforced namespace restrictions, extending its hardening line from allocator and browser work into removing an entire privilege class (secureblue Project 2026b). NixOS 26.05 ships without the long-debated hardened profile — removed from nixpkgs rather than merely deprecated (community 2026b) — with the NixOS Hardening wiki now serving as the documented baseline an operator assembles from (community 2026a). Talos 1.12 made its TPM measurement policies configurable, so a fleet can state which PCRs seal what (Labs 2025). Each release lowers the

Scenario recommendations I

operational cost of keeping a recommendation that was already the architectural judgment; none of them changes a direction, and none converts a moderate row into a high one.

The strongest overall direction

The strongest overall direction I

The strongest synthesis across the reviews is: **Qubes-like containment, Nix-like reproducible operations, strong boot and update integrity, and capability-limited agents.** This is a design target, not a product claim. No reviewed system ships all four properties as a default, and they are exactly the non-substitutable set that sec. 4 argues must be evaluated separately: containment without reproducible operations decays; reproducible operations without containment standardizes a single wide domain; both without boot and update integrity rest on an unverified foundation; all three without capability-limited agents leave the authorized-misuse path open (sec. 10). The trust-domain architecture of tbl. 8 is the operating plan for the target, and the operator and orchestration disciplines of sec. 12 and sec. 13 are what keep it standing during real work.

The strongest overall direction I

The design-target framing carries a practical corollary: a well-maintained implementation of part of this design can be safer than an ambitious combination whose integration nobody reliably owns. The Qubes-plus-NixOS combination is the standing example. Community work on a NixOS template exists (Q. O. Project 2026b), but community templates do not receive updates from the Qubes project itself (Q. O. Project 2026c), and the integration — not either component — is where maintenance risk accumulates (sec. 6). Ownership is part of the security property: who reviews the composition, who patches it, who rehearses its recovery. An unowned maximal stack decays into exactly the neglected-architecture failure that sec. 5 and sec. 6 both document, while a smaller, owned one compounds its advantages over time.

Confidence tiers and evidence limits

Confidence tiers and evidence limits I

tbl. 2 states what this review claims, with what confidence, and what limits the evidence behind each claim.

Confidence tiers and evidence limits

Table 2: The confidence tiers and evidence limits attached to this review's principal claims

Confidence tier	Claim	Evidence basis and limits
High	The properties are independent: build reproducibility, boot integrity, runtime isolation, anonymity, and agent authorization answer different questions, and no sound selection substitutes one for another	Follows from the property definitions of sec. 4; structural, not an empirical measurement
High	Excessively broad legitimate access is dangerous independently of exploit resistance; the AISI incident is the key precedent — its own report distinguishes permitted internet activity from sandbox escape, with out-of-scope actions in 10 of 122 runs inside an intact sandbox and no resulting real-world harm found (Institute 2026)	A primary incident report; its authors note the configurations were not representative of public access — the lesson is structural, not a base rate
Moderate	Qubes is the strongest fit among the reviewed deployable workstation candidates for this compartmentalization-centered threat model, under substantial operational conditions (Q. O. Project 2026a)	An architectural assessment from documented design and advisories, not a measured probability of resisting any particular attacker
Moderate	secureblue is a particularly interesting conventional-desktop candidate, and NixOS a particularly strong compositional platform, pending independent audit coverage and patch-latency evidence (secureblue Project 2026a; N. Project 2026)	Project-documented features; public descriptions do not settle comparative implementation quality, audit coverage, or time-to-patch

Confidence tiers and evidence limits II

Low

Any unconditional prediction of which named distribution will be most secure across 2028–2031

Declined: project execution, hardware changes, ecosystem support, and unknown vulnerabilities can reorder the field; the review does not manufacture a winner

Confidence tiers and evidence limits I

The high-confidence rows are structural. Property independence follows from the definitions, and the authorized-misuse danger is demonstrated rather than projected: the AISI report is an incident report by the organization that ran the testing, and its value is precisely that it documents unsanctioned agent behavior without a sandbox escape (Institute 2026). The moderate rows are architectural judgments with conditions attached, not probabilities; they weaken under the stated change conditions rather than under argument. It is worth noting where official posture now sits relative to that moderation: the CISA-led Five Eyes guidance on careful adoption of agentic AI services recommends sandboxed deployment, staged low-risk-task adoption, threat-model-based evaluation, and red-teaming (Cybersecurity and Agency 2026) — a guarded-adoption posture convergent with, though independent of, this

review's moderate tiers. Convergence is not corroboration of the specific platform judgments, which remain assessments from documented design; it does indicate that the posture itself is no longer idiosyncratic. The low-confidence row is a refusal, consistent with the forecast posture of sec. 15.

Evidence limits I

The review relied principally on official documentation, project security advisories, and primary incident or research reports, with developer discussions used for specific integration caveats. It did not install the candidates, formally audit their policies, verify the reproducibility of their images, or run offensive-agent trials against them. Where current defaults or security properties were not verified, the comparison labels them n.a. or withholds the stronger claim — as with the unverified role-specific defaults noted for MicroOS in sec. 8 and the unverified boot-integrity baseline noted for Kicksecure in sec. 7. Absence of a confirmed feature in this review is not evidence that the feature is unavailable; it is a statement about this review's evidence. Readers extending this work should treat the scenario table as a starting position to be

re-derived under their own assumptions, using the properties of sec. 4 rather than distribution labels.